
Rúbrica Práctica 3: API REST y seguridad

Introducción

La práctica recibirá una calificación en base al análisis del vídeo que muestra su funcionamiento, de su código fuente y de su documentación.

Esta calificación se calcula de la siguiente forma

- Se parte de una calificación de 10 (máxima).
- Por cada elemento de la rúbrica que no se cumpla (o lo haga con deficiencias, se descontará la calificación indicada).

Vídeo

Se grabará un vídeo mostrando la funcionalidad de la aplicación. Se dividirá en las siguientes partes:

- Funcionalidades de un usuario no registrado.
- Funcionalidades de un usuario registrado. Si es necesario se usarán varios usuarios (usando varios navegadores web) para que se observe cómo las acciones de un usuario afectan a otro (mensajes, valoraciones, comentarios, solicitudes de amistad, etc.)
- Funcionalidades del administrador.

Cada vez que en el vídeo aparezca una funcionalidad determinada, se deberá reflejar el tipo de funcionalidad con un subtítulo. Los subtítulos se asociarán al vídeo utilizando un fichero de subtítulos .srt.

El subtítulo concreto que debe aparecer se identifica en **negrita** por cada funcionalidad.

IMPORTANTE: Si alguna funcionalidad de las que solicitan a continuación no se muestra en el vídeo se considerará que no está implementada y se le aplicará su penalización correspondiente, aunque este en el código.

Funcionalidades requeridas

1. ¿Existe un endpoint de login que permita iniciar sesión? Si | No (-3)
 - “Endpoint de login”
2. ¿Existe un endpoint de signup que permita registrar un nuevo usuario? Si | No (-3)
 - “Endpoint de registro”
3. ¿Existen endpoints paginados para listar los elementos de todas las entidades? Si | Faltan

- datos de ejemplo (-2) | Faltan cosas importantes (-3) | No (-10)
- **"Endpoint listado de X"**
4. ¿Existen endpoints para consultar en detalle aquellos elementos en los que tenga sentido visualizarlo de manera individual? Si | No (-2)
 - **"Endpoint detalle de X"**
 5. ¿Existen endpoints para crear los elementos de todas las entidades? Si | Faltan cosas menores (-1) | Faltan cosas importantes (-3) | No (-10)
 - **"Endpoint creación de X"**
 6. ¿Al menos en una entidad se valida al menos un campo en su creación? Si | No se da un mensaje de error apropiado (-1) | No/No se realiza en el servidor (-2)
 - **"Validación de campo"**
 7. ¿Existen endpoints para borrar los elementos de todas las entidades? Si | Faltan cosas menores (-1) | Faltan cosas importantes (-3) | No (-10)
 - **"Endpoint borrado de X"**
 8. ¿Existen endpoints para editar los elementos que tiene sentido que se puedan modificar? Si | No (-2)
 - **"Endpoint edición de X entidad"**
 9. ¿Existe un endpoint para visualizar las imágenes? Si | No (-2)
 - **"Endpoint imagen X entidad"**
 10. ¿Existe control de acceso por rol y URL (por ejemplo, los usuarios registrados no pueden acceder a las URLs del administrador)? Si | Faltan cosas menores (-2) | No (-5.5)
 - Incluir en el vídeo: Deberá mostrarse en el video que al acceder a un endpoint de administrador con un usuario registrado se muestra un error.
 - **"Endpoint control de acceso por rol"**
 11. ¿Existe control de acceso por dueño del objeto (un usuario no-administrador no puede acceder/editar/borrar información que es propiedad de otro usuario)? Si | No (-5.5)
 - Incluir en el vídeo: Se intenta modificar/borrar desde un endpoint conectado con un usuario, el objeto a través de su ID de otro usuario.
 - **"Endpoint control de acceso por dueño"**
 12. ¿Se muestran correctamente los errores cuando falla la API REST con JSON? Si | No, aparece código HTML (-2)
 - **"Endpoint error"**
 13. ¿La aplicación ofrece también el interfaz web? Si | No (-4)
 - **"Web"**
 14. ¿Se ha implementado el campo con texto enriquecido y se visualiza correctamente (en web

y REST)? Si | No (-5.5)

- “Texto enriquecido”

15. ¿Se ha implementado la funcionalidad que permite guardar un fichero en disco ligado a una entidad (con su nombre original) y se permite recuperar dicho fichero para su visualización (en web y REST)? Si | No (-5.5)

- “Fichero en disco”

Vulnerabilidades y Contramedidas

Se califican los siguientes aspectos:

16. ¿La aplicación tiene alguna vulnerabilidad vista en clase? No | Si (-5.5)

Código fuente y documentación

Se califican los siguientes aspectos:

17. ¿La colección Postman utiliza la variable `{{baseUrl}}` para poder ejecutarse tanto en localhost como en despliegue remoto? Si | No (-1)

18. ¿Se han reutilizado los servicios entre RestController y web Controller? Si | No (-2)

19. ¿La API REST está diseñada teniendo en cuenta las buenas prácticas (uso correcto de los métodos HTTP, URLs con recursos en inglés y en plural, uso correcto de los códigos de estado, header Location en creación, filtros en parámetros de URL y ausencia de verbos en las URLs)? Si | Hay algunas deficiencias (-0,5) | Deficiencias importantes (-2)

20. ¿Todas las URLs de la API REST comienzan con `/api/v1/`? Si | No (-0,5)

21. ¿Los controladores REST usan DTOs en lugar de entidades para procesar la entrada y salida? Si | no (-2)

22. ¿Endpoint que lista usuarios devuelve la contraseña en claro o cifrada? No | En claro (-5) | Cifrada (-3)

23. ¿La protección contra CSRF está desactivada en la API REST y sigue activa en la web? Si | No (-1)

24. ¿El código y los comentarios están en inglés? Si | Mayormente en inglés, pero hay castellano (-0,5) | No (-1)

25. ¿El código tiene un formato y estilo adecuado? Si | Algunas reglas no se cumplen (-0,5) | No (-1,5)

26. ¿La API REST está documentada con OpenAPI generado mediante SpringDoc y se encuentra en la carpeta `/api-docs` de la raíz del repositorio e incluye `api-docs.yaml` y `api-docs.html`? Si | No (-2)

27. ¿En el README hay un enlace a la especificación OpenAPI y un enlace a la documentación HTML visualizable correctamente? Si | No (-0,5)

- 28. ¿La documentación contiene un diagrama de clases actualizado con las nuevas clases @RestController y los servicios compartidos? Si | No (-1)
- 29. ¿La documentación contiene información sobre la participación de cada miembro del equipo? Si | No (-3)